# Chapter 5

# Fundamentals of Cloud Security



**By Tagel W.(M.Sc.)**

*tagel.12wogayehu@gmail.com*

# Outlines


Basic Terms and Concepts
Threat Agents
Cloud Security Threats

# Basic Terms and Concepts

# Basic Terms and Concepts

- Cloud security is a set of policies, controls, procedures and technologies that should work together to protect your cloud-based applications and systems.
- Information security is a complex combination of techniques, technologies, regulations, and behaviors that collaboratively protect the *integrity of and access to computer systems and data.*
- IT security measures aim to defend against threats and interference that arise from both malicious intent and unintentional user error.

# Basic Terms in Cloud Security

- Confidentiality
- Integrity
- Authenticity
- Availability

characteristics that can be associated with measuring security.

- Threat
- Vulnerability
- Risk

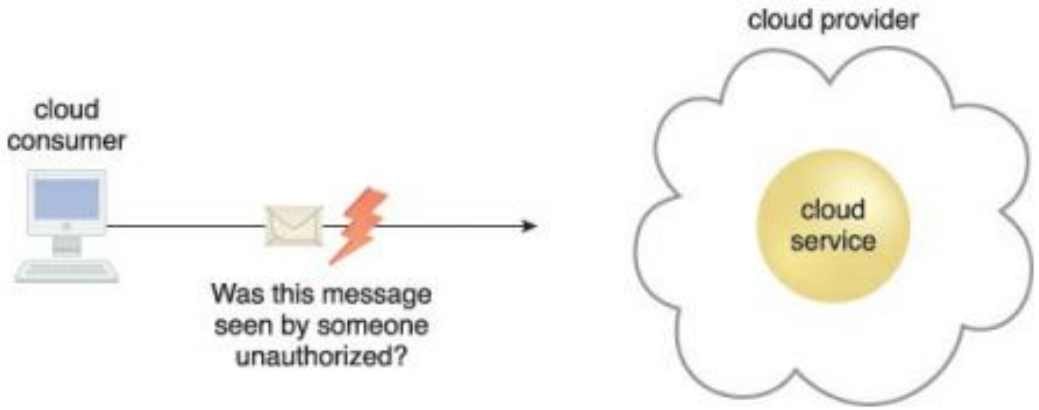
associated with measuring and assessing insecurity, or the lack of security

countermeasures and safeguards

- Security Controls / Mechanisms
- Security Policies

# Confidentiality

- Confidentiality is the characteristic of something being made accessible only to authorized parties .
- Within cloud environments, confidentiality primarily pertains to restricting access to data in transit and storage.




The message issued by the cloud consumer to the cloud service is considered confidential only if it is not accessed or read by an unauthorized party.

# Integrity

- Integrity is the characteristic of not having been altered by an unauthorized party
- An important issue that concerns data integrity in the cloud is whether a cloud consumer can be guaranteed that the data it transmits to a cloud service matches the data received by that cloud service.
- Integrity can extend to how data is stored, processed, and retrieved by cloud services and cloud-based IT resources.
- The message issued by the cloud consumer to the cloud service is considered to have integrity if it has not been altered.

# Authenticity

- Authentication is the process of determining the identity of a client.
- Authenticity is the characteristic of something having been provided by an authorized source.
- This concept encompasses non-repudiation, which is the inability of a party to deny or challenge the authentication of an interaction.
- Authentication in non-repudiable interactions provides proof that these interactions are uniquely linked to an authorized source.

# Availability

- Availability is the characteristic of being accessible and usable during a specified time period.
- In typical cloud environments, the availability of cloud services can be a responsibility that is shared by the cloud provider and the cloud carrier.
- The availability of a cloud-based solution that extends to cloud service consumers is further shared by the cloud consumer.

# Threat

- A threat is a potential security violation that can challenge defenses in an attempt to breach privacy and/or cause harm.
- Both manually and automatically instigated threats are designed to exploit known weaknesses, also referred to as vulnerabilities.
- A threat that is carried out results in an attack.

# Vulnerability

- A vulnerability is a weakness that can be exploited either because it is protected by insufficient security controls, or because existing security controls are overcome by an attack.
- IT resource vulnerabilities can have a range of causes, including configuration deficiencies, security policy weaknesses, user errors, hardware or firmware flaws, software bugs, and poor security architecture.

# Risk

- Risk is the possibility of loss or harm arising from performing an activity.
- Risk is typically measured according to its threat level and the number of possible or known vulnerabilities.
- Two metrics that can be used to determine risk for an IT resource are:
  - **the probability of a threat occurring to exploit vulnerabilities in the IT resource**
  - **the expectation of loss upon the IT resource being compromised**

# Security Controls/Security Mechanisms

- Security controls are countermeasures used to prevent or respond to security threats and to reduce or avoid risk.
- Countermeasures are typically described in terms of security mechanisms, which are components comprising a defensive framework that protects IT resources, information, and services.

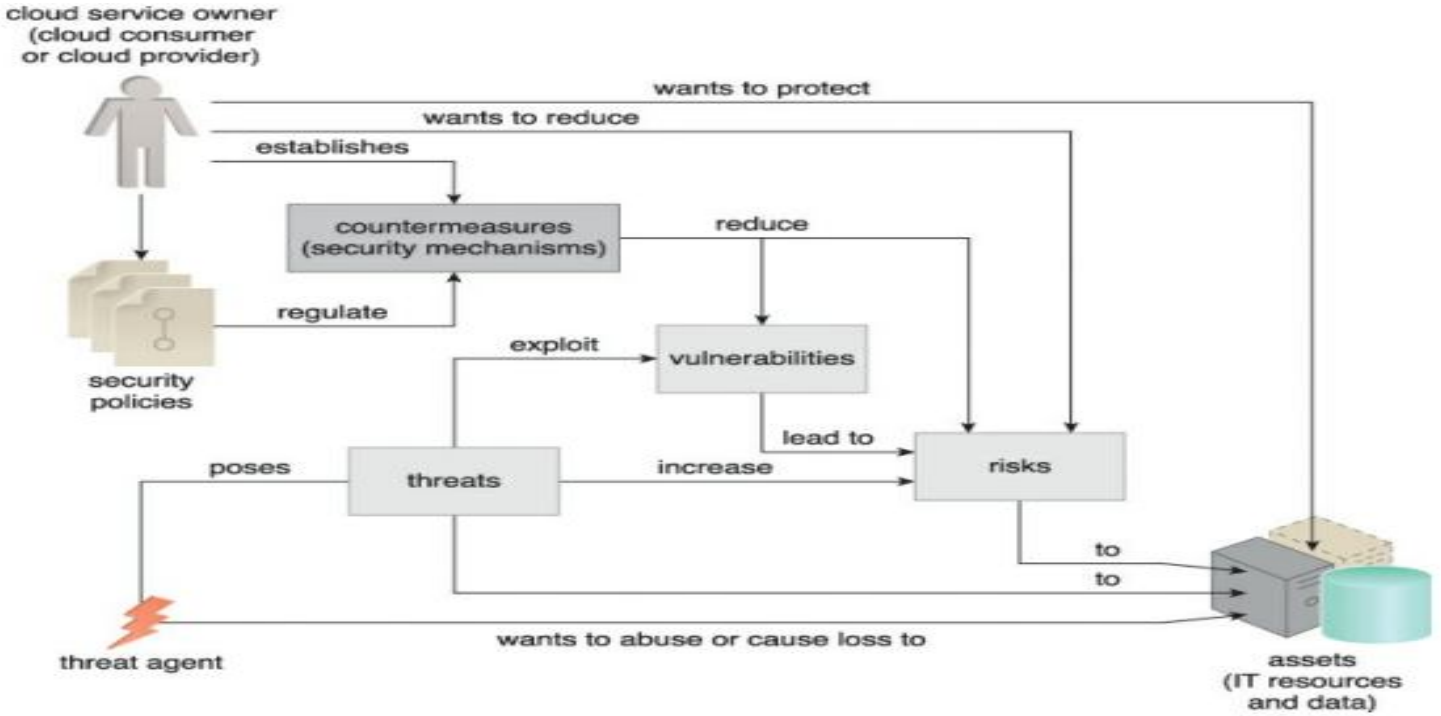
# Security Policies

- A security policy establishes a set of security rules and regulations.
- Often, security policies will further define how these rules and regulations are implemented and enforced.

# *Threat Agents*

# Threat Agents

- A threat agent is an entity that poses a threat because it is capable of carrying out an attack.
- Cloud security threats can originate either internally or externally, from humans or software programs.




How security policies and security mechanisms are used to counter threats, vulnerabilities, and risks caused by threat agents.

# Anonymous Attacker



- An anonymous attacker is a non-trusted cloud service consumer without permissions in the cloud.
- It typically exists as an external software program that launches network-level attacks through public networks.
- When anonymous attackers have limited information on security policies and defenses, it can inhibit their ability to formulate effective attacks.
- Therefore, anonymous attackers often resort to committing acts like by passing user accounts or stealing user credentials, while using methods that either ensure anonymity or require substantial resources for prosecution

# Malicious Service Agent



- A malicious service agent is able to intercept and forward the network traffic that flows within a cloud .
- It typically exists as a service agent (or a program pretending to be a service agent) with compromised or malicious logic.
- It may also exist as an external program able to remotely intercept and potentially corrupt message contents.

# Trusted Attacker



- A trusted attacker shares IT resources in the same cloud environment as the cloud consumer and attempts to exploit legitimate credentials to target cloud providers and the cloud tenants with whom they share IT resources .
- Unlike anonymous attackers (which are non-trusted), trusted attackers usually launch their attacks from within a cloud's trust boundaries by abusing legitimate credentials or via the appropriation of sensitive and confidential information.
- Trusted attackers (also known as malicious tenants) can use cloud-based IT resources for a wide range of exploitations, including the hacking of weak authentication processes, the breaking of encryption, the spamming of e-mail accounts, or to launch common attacks, such as denial of service campaigns.

# Malicious Insider



- Malicious insiders are human threat agents acting on behalf of or in relation to the cloud provider.
- They are typically former employees or third parties with access to the cloud provider's premises.
- This type of threat agent carries tremendous damage potential, as the malicious insider may have administrative privileges for accessing cloud consumer IT resources.

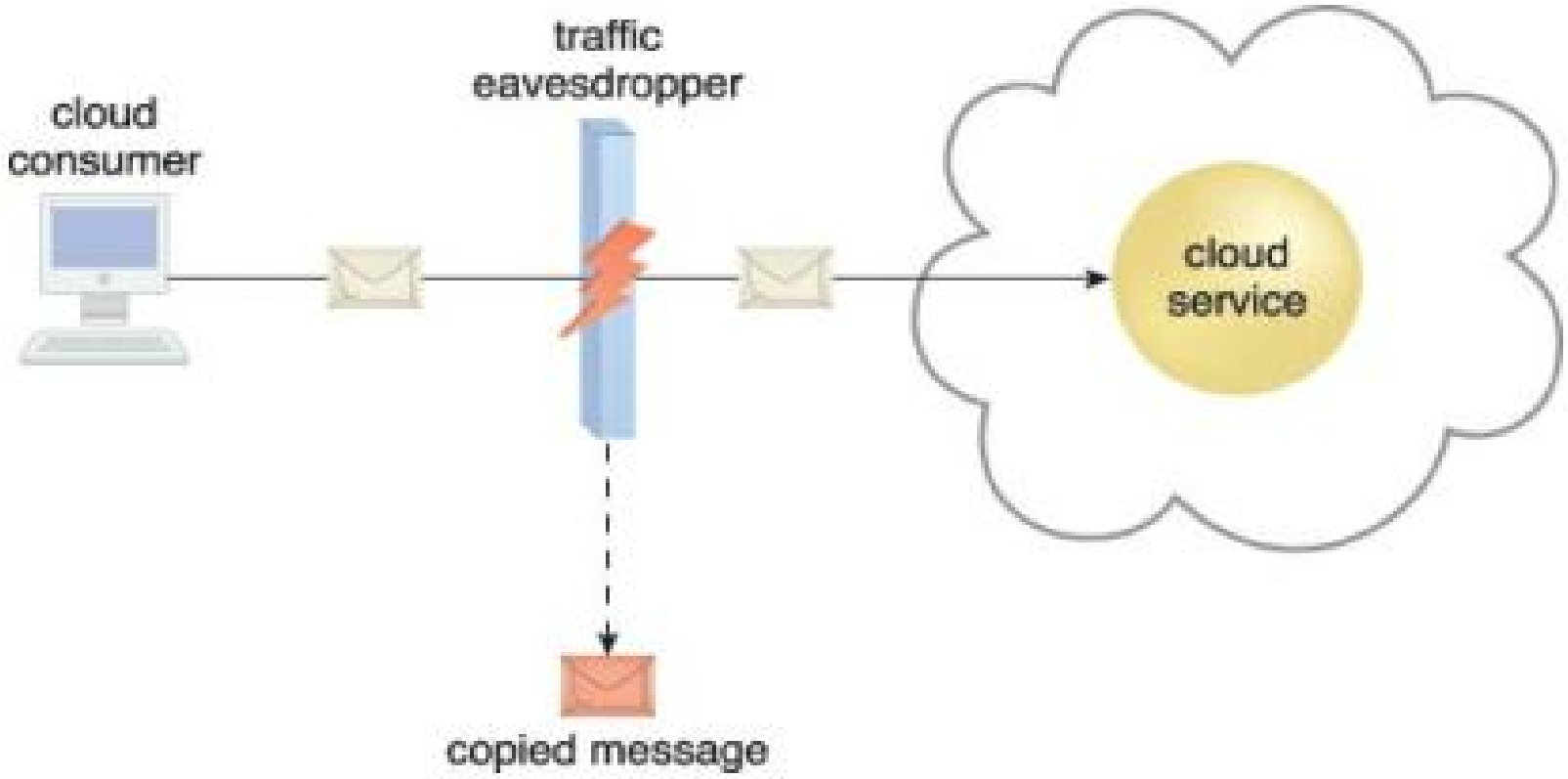
# *Cloud Security Threats*

# Cloud Security Threats

- Traffic Eavesdropping
- Malicious Intermediary
- Denial of Service
- Insufficient Authorization
- Virtualization Attack

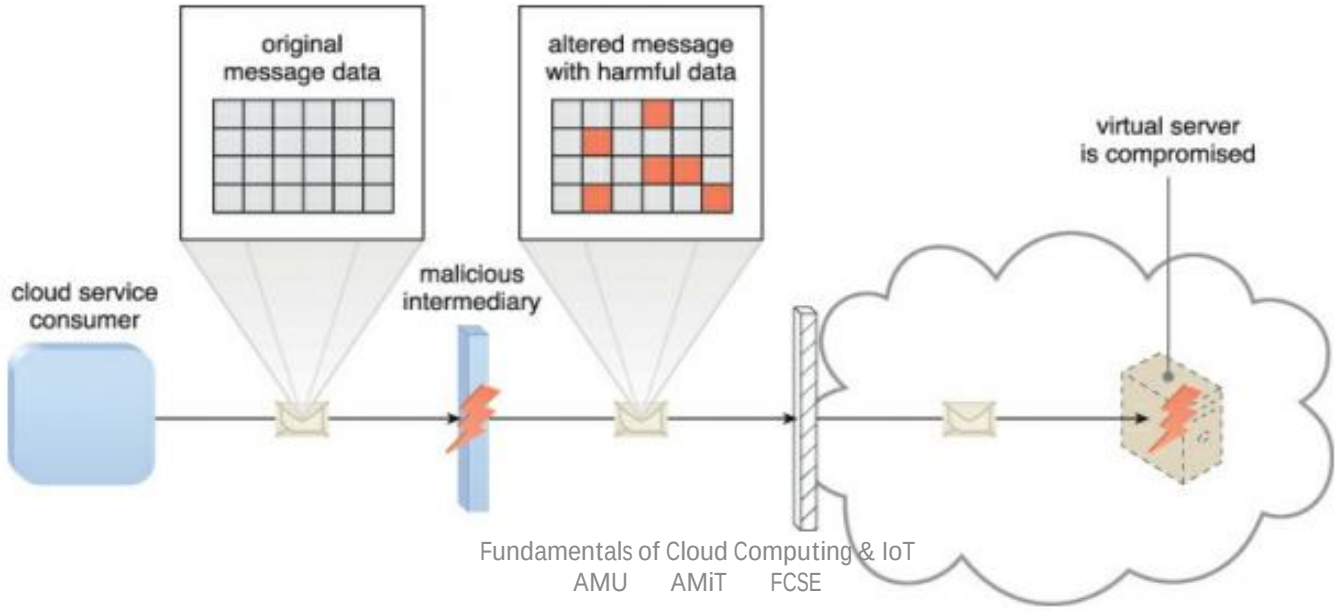
# Traffic Eavesdropping

- Traffic eavesdropping occurs when data being transferred to or within a cloud (usually from the cloud consumer to the cloud provider) is passively intercepted by a malicious service agent for illegitimate information gathering purposes .
- The aim of this attack is to directly compromise the confidentiality of the data and, possibly, the confidentiality of the relationship between the cloud consumer and cloud provider.
- Because of the passive nature of the attack, it can more easily go undetected for extended periods of time.


traffic
eavesdropper
cloud
consumer
cloud
service
copied message

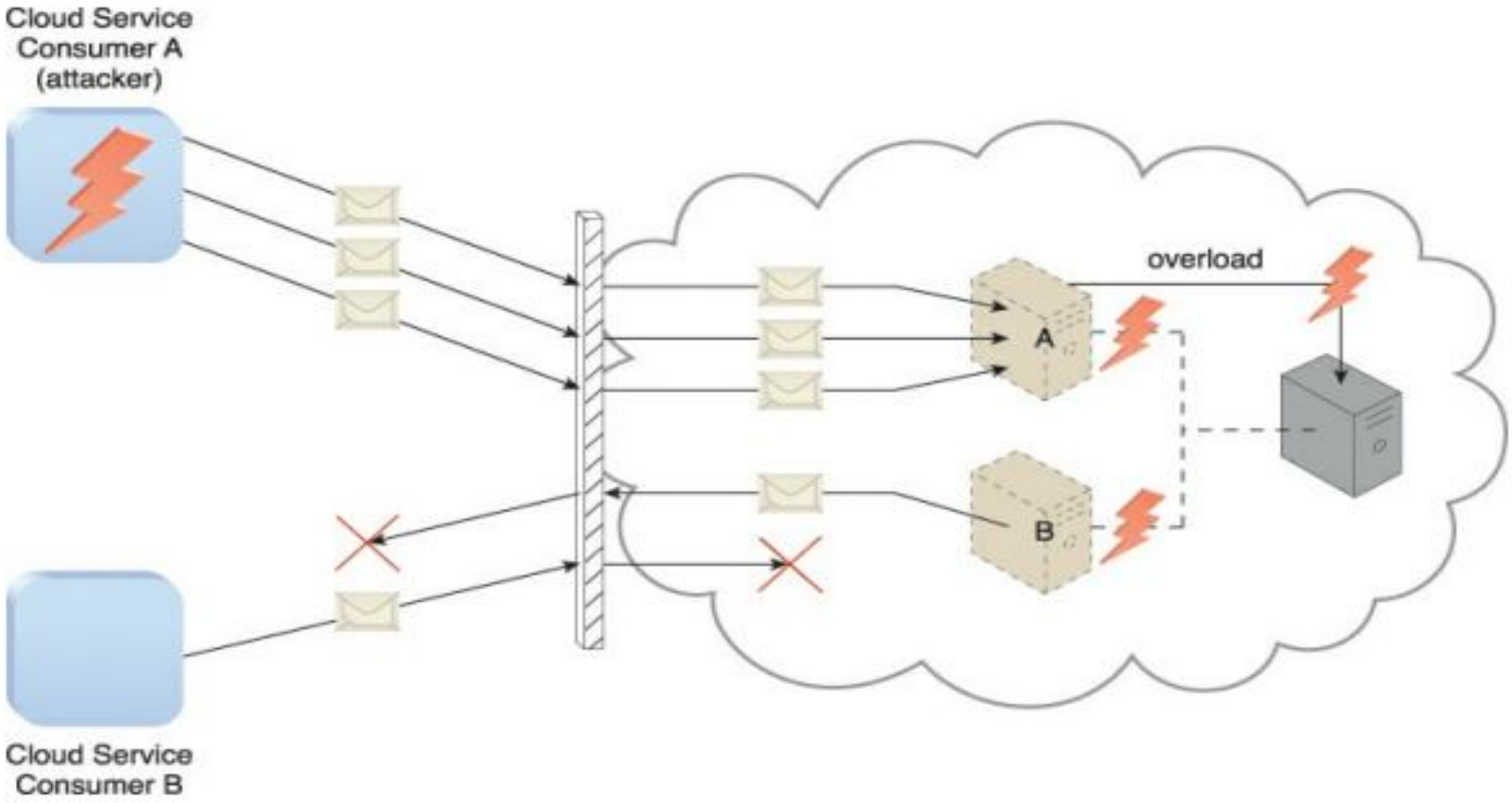
# Malicious Intermediary

- The malicious intermediary threat arises when messages are intercepted and altered by a malicious service agent, thereby potentially compromising the message's confidentiality and/or integrity.
- It may also insert harmful data into the message before forwarding it to its destination.



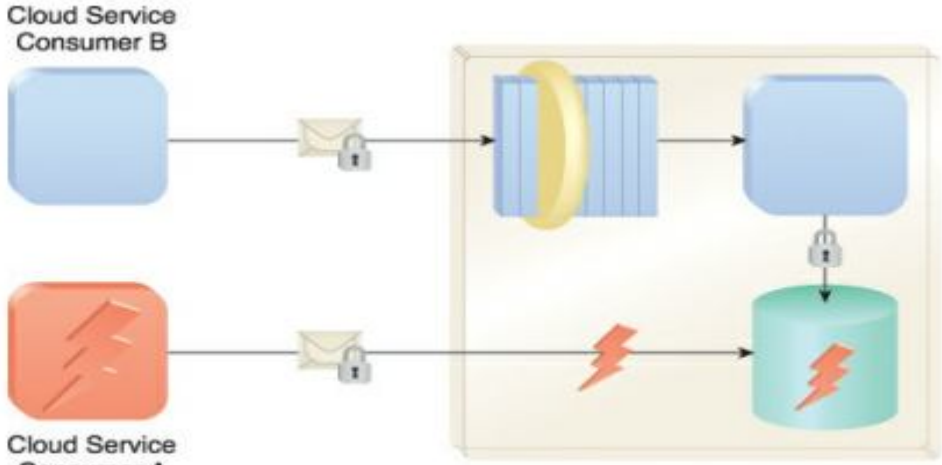
# Denial of Service

- The objective of the denial of service (DoS) attack is to overload IT resources to the point where they cannot function properly.
- This form of attack is commonly launched in one of the following ways:
  - The workload on cloud services is artificially increased with imitation messages or repeated communication requests.
  - The network is overloaded with traffic to reduce its responsiveness and cripple its performance.
  - Multiple cloud service requests are sent, each of which is designed to consume excessive memory and processing resources.
- Successful DoS attacks produce server degradation and/or failure.


Cloud Service
Consumer A
(attacker)
overload
A
B
Cloud Service
Consumer B

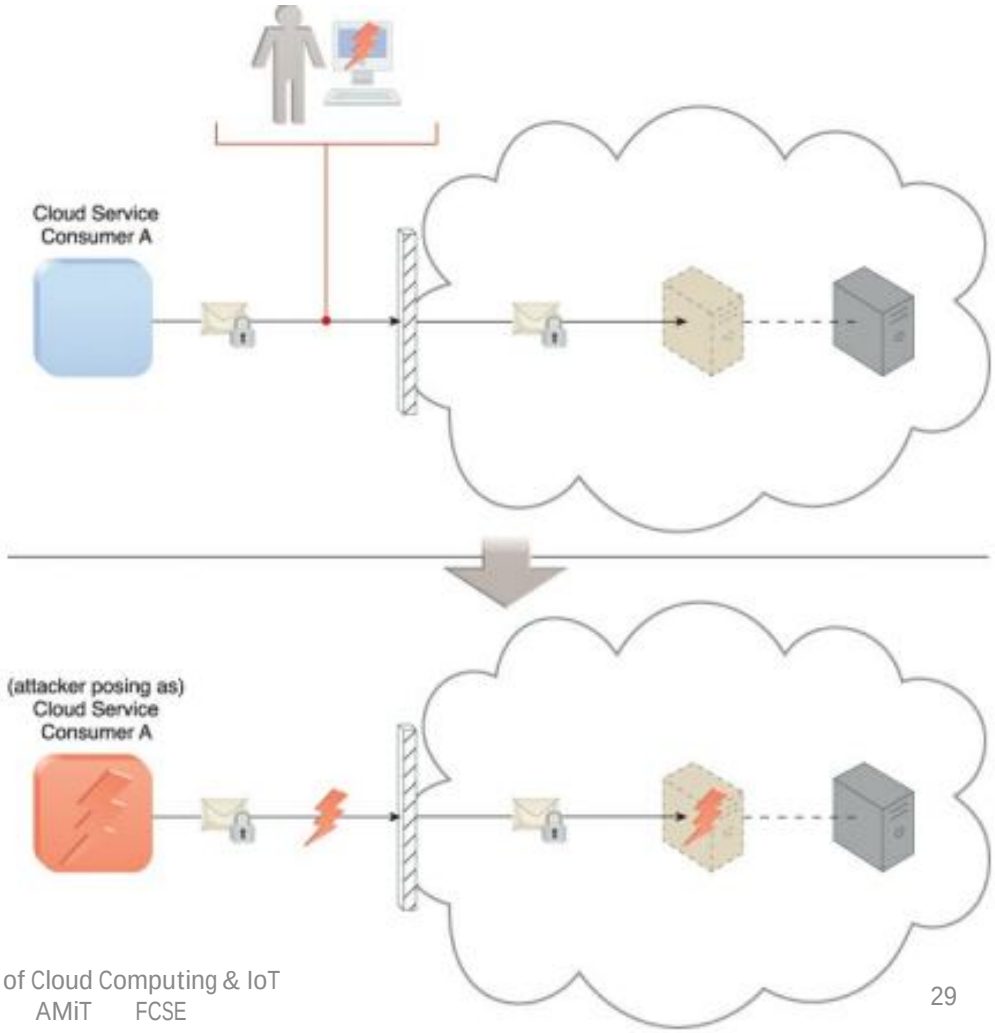
# Insufficient Authorization

- The insufficient authorization attack occurs when access is granted to an attacker erroneously or too broadly, resulting in the attacker getting access to IT resources that are normally protected.
- This is often a result of the attacker gaining direct access to IT resources that were implemented under the assumption that they would only be accessed by trusted consumer programs.



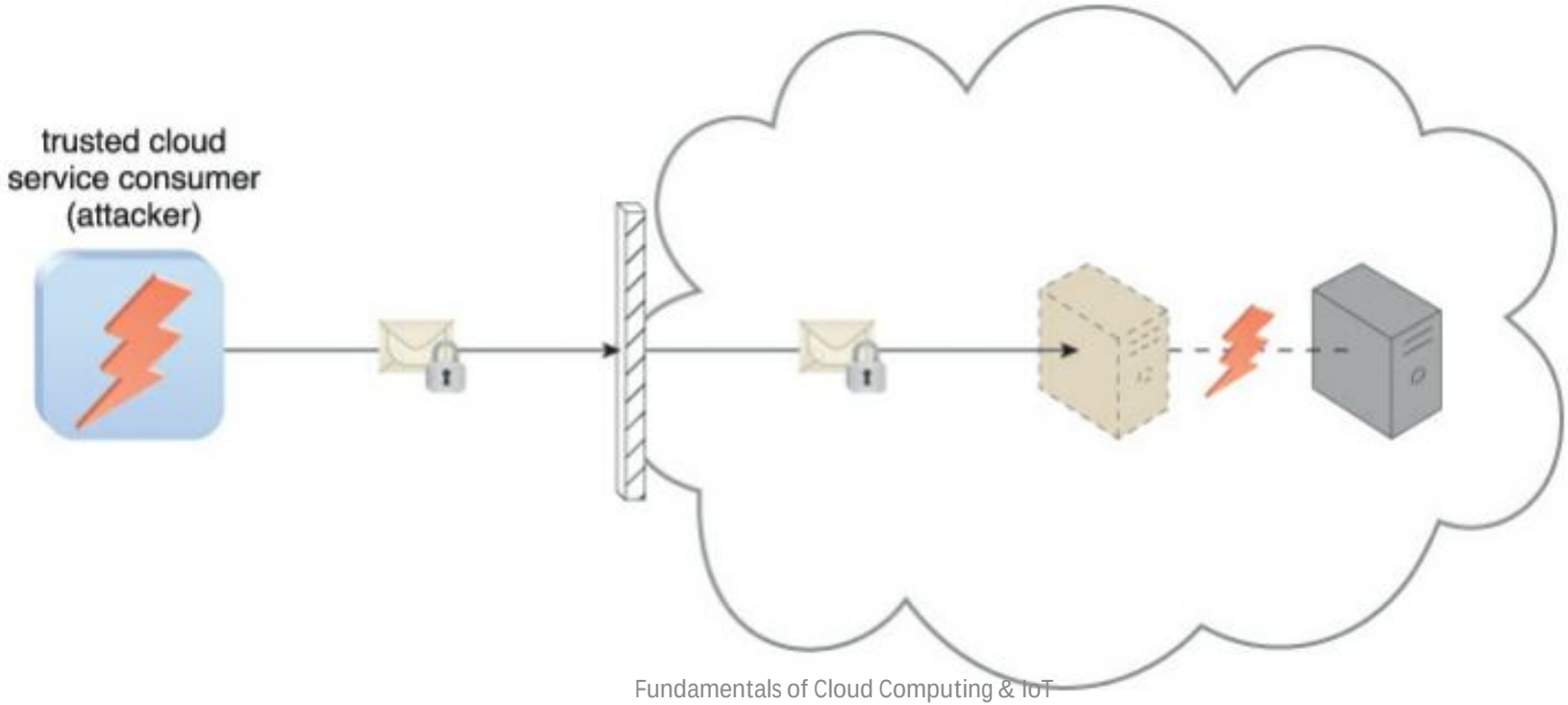
# Insufficient Authorization *weak authentication*

- A variation of **Insufficient Authorization** attack, known as weak authentication, can result when weak passwords or shared accounts are used to protect IT resources.
- Within cloud environments, these types of attacks can lead to significant impacts depending on the range of IT resources and the range of access to those IT resources the attacker gains.



# Virtualization Attack

- This is an attack to the underlying physical IT resources.
- A virtualization attack exploits vulnerabilities in the virtualization platform to jeopardize its confidentiality, integrity, and/or availability.



***So how to solve these, and Such Cloud Security issues?***

# Ways to Improve Cloud Security

- Next-Generation Firewall (NGFW)
- Deploy Multi-Factor Authentication (MFA)
- Monitoring & Logging
- Ensuring Data Security
- Cloud Security Training for Employees
- Off-boarding Process for Departing Employees

……..etc……..

# End of Chapter-5 & the Course!

**Qn. if Any???**

